

PENETRATION TESTING REPORT

Mediroza General Hospital
<https://medirozahospital.com>

Client	Mediroza General Hospital
Engagement Type	Black-box Penetration Test & Vulnerability Assessment
Target	https://medirozahospital.com
Duration	3 Days (Batch B082 Week 4)
Report Date	06 September 2026
Classification	CONFIDENTIAL — Authorised Personnel Only

Prepared for Networkwalks Educational Engagement
This report is confidential and intended solely for the authorised client and instructors.

1. Executive Summary

A black-box penetration test was conducted against the web infrastructure of Mediroza General Hospital (<https://medirozahospital.com>) in a controlled educational environment with explicit written authorisation. The objective was to identify vulnerabilities, demonstrate real-world impact through controlled exploitation, and provide actionable remediation guidance.

The assessment successfully achieved all defined milestones. Critical and high-severity vulnerabilities were discovered that allowed unauthorised access to confidential patient laboratory reports, recovery of their encrypted contents, and exposure of the entire hospital staff payroll and shareholder register.

Key Findings Summary

Finding	Severity	Impact
SQL Injection in Patient Portal Login	Critical	Full unauthenticated access to patient lab reports
Weak PDF encryption passwords	High	Confidential patient medical data recoverable
Sensitive database backup publicly exposed	Critical	Complete staff salaries + shareholder details leaked
Directory listing enabled on /old/	High	Sensitive files discoverable without authentication
Sensitive metadata in PDF documents	Medium	Internal operational details and file paths leaked

Overall risk to the organisation is assessed as **Critical**. Immediate remediation of the SQL injection and removal of the publicly accessible database backup is strongly recommended before any production use.

2. Scope and Methodology

2.1 Scope

The engagement was limited to the single domain **<https://medirozahospital.com>** and its associated web application components. Social engineering, denial-of-service attacks, and testing of systems outside the agreed target were explicitly out of scope.

2.2 Rules of Engagement

- Testing restricted to the target domain only
- No social engineering
- No denial-of-service testing
- Written authorisation provided by the client / Networkwalks

2.3 Methodology

A standard black-box approach was followed, progressing through reconnaissance, vulnerability identification, exploitation, and post-exploitation analysis. Techniques included:

- Passive and active reconnaissance (robots.txt, directory enumeration, source review)
- Manual testing of authentication mechanisms for injection flaws
- Controlled exploitation of confirmed SQL injection
- Password recovery against encrypted PDF documents using dictionary attacks
- Metadata and file-property analysis of retrieved artefacts
- Review of exposed backup files and sensitive data stores

2.4 Tools Used

curl, Python (pypdf), John the Ripper wordlists, manual SQL injection payloads, and standard Linux utilities for file analysis.

2.5 Limitations

Testing was performed from a single external perspective without authenticated staff credentials or internal network access. Only the publicly reachable web application was assessed.

3. Findings and Proof of Exploitation

3.1 SQL Injection – Patient Portal Authentication Bypass (Critical)

Location: POST /patient/login.php (username parameter)

Description: The patient portal login endpoint constructs SQL queries by directly concatenating user-supplied input without parameterisation or adequate sanitisation. An error-based SQL injection was confirmed, and authentication could be completely bypassed.

Proof of Concept:

Payload submitted in the username field: admin' --

The application returned HTTP 302 and redirected to /patient/portal.php, establishing an authenticated session. Once inside the portal, three confidential encrypted patient pathology reports were listed and successfully downloaded (Lab Refs LR-2024-1187, LR-2024-1192, LR-2024-1205 belonging to S. Dlamini, P. Reddy and E. Thompson).

3.2 Weak Encryption on Patient Lab Reports (High)

Description: The three retrieved PDF laboratory reports were protected with Adobe Standard security (RC4 128-bit). The passwords chosen were extremely weak and were recovered using common dictionaries:

- patient_report_1.pdf → password: 123456
- patient_report_2.pdf → password: password
- patient_report_3.pdf → password: !@#\$%^&

Full medical results (haematology, lipid profiles, iron studies, etc.) were recovered, demonstrating that the encryption provided no meaningful confidentiality protection.

3.3 Publicly Accessible Database Backup Containing HR & Shareholder Data (Critical)

Location: https://medirozahospital.com/old/mediroza_db_backup_2019.sql

Discovery path: The third decrypted PDF contained metadata Comments field stating: “DB backup moved to /old before site migration, do not delete”. Directory listing was enabled on /old/, exposing the SQL dump without any authentication.

The dump contains the complete **staff** table (30 employees) with full names, job titles, departments, email addresses, phone numbers, national ID numbers, monthly salaries in ZAR, and dates of joining, plus the complete **shareholders** table (10 entries) with ownership percentages and share classes.

Staff Salary Summary (selected high-value records):

Name	Title	Salary (ZAR)
Dr. Johan van der Merwe	Medical Director	160,000
Sarah Botha	Chief Financial Officer	152,000
Dr. Rajesh Naidoo	Chief Pathologist	138,000
Dr. Vikram Chetty	Anaesthetist	135,000
Dr. Anita Naicker	Consultant Cardiologist	132,000
... (25 further records)	Full list retained in evidence	—

Shareholder Register:

Shareholder	%	Shares	Class
Dr. Rajesh Naidoo	18.0	180,000	Ordinary
Cedar Health Holdings (Pty) Ltd	15.0	150,000	Ordinary
Dr. Johan van der Merwe	12.0	120,000	Ordinary
Reddy Family Trust	11.0	110,000	Ordinary
Thabo Molefe	10.0	100,000	Ordinary

Sarah Botha	9.0	90,000	Ordinary
Dr. Ahmed Kara	8.0	80,000	Preferential
Naledi Zulu	7.0	70,000	Ordinary
Michael Roberts	6.0	60,000	Ordinary
Dr. Vikram Chetty	4.0	40,000	Preferential

Evidence of the exposure (full SQL dump) has been retained and is available in the supporting artefacts.

3.4 Directory Listing Enabled (High)

The /old/ directory returned a full autoindex listing, making the presence of the database backup immediately obvious to any visitor. Combined with the metadata hint, this removed any requirement for blind discovery.

3.5 Sensitive Information in Document Metadata (Medium)

PDF metadata revealed internal usernames (j.malik), operational comments about database migration, and tool names (Mediroza CMS 1.4.2, Mediroza Lab Reporting Module). This information aided further discovery and would assist a real attacker in social engineering or targeted follow-up attacks.

4. Risk Rating

Risk ratings use a qualitative scale of Critical / High / Medium / Low based on likelihood of exploitation and potential business impact (confidentiality, integrity, regulatory exposure under POPIA, reputational harm, and financial loss).

Finding	Likelihood	Impact	Risk
SQL Injection (Patient Portal)	High – trivial payload	Critical – patient data access	Critical
Exposed HR/Shareholder DB backup	High – public URL	Critical – payroll & ownership data	Critical
Weak PDF passwords	High – dictionary recoverable	High – medical results exposed	High
Directory listing on /old/	High	High – enables discovery	High
Sensitive PDF metadata	Medium	Medium – aids attackers	Medium

Overall organisational risk rating: Critical. Two independent critical findings alone justify immediate executive attention and prioritised remediation.

5. Recommendations and Remediation

5.1 Immediate (Critical – within 24–48 hours)

1. **Fix SQL Injection:** Replace all dynamic SQL construction with parameterised queries / prepared statements. Validate and encode all user input. Deploy a Web Application Firewall (WAF) rule set as a temporary compensating control.
2. **Remove exposed backup:** Immediately delete or move the file at /old/mediroza_db_backup_2019.sql to a non-web-accessible location. Disable directory listing on the web server (Options -Indexes).
3. **Rotate credentials & review access:** Assume the exposed data may already have been copied. Force password resets for any accounts that could be derived from the dump and review access logs.

5.2 Short-term (High priority – within 1–2 weeks)

4. **Strengthen document encryption:** Enforce strong, randomly generated passwords (or better, certificate-based or server-side access control) for any documents containing PHI. Never embed weak shared passwords.
5. **Strip sensitive metadata:** Implement a document sanitisation step that removes Author, Comments, Creator and other metadata before documents are made available to patients or external parties.
6. **Secure backup processes:** Ensure all database and configuration backups are stored outside the web root, encrypted at rest, and accessible only via authenticated administrative channels.

5.3 Medium-term / Hardening

7. Conduct a full source-code review of the Mediroza CMS authentication and data-access layers.
8. Implement proper session management, account lockout, and multi-factor authentication for both patient and staff portals.
9. Establish a secure development lifecycle (SDL) including regular dependency scanning, static analysis, and periodic external penetration tests.
10. Review POPIA (and any applicable privacy legislation) compliance given the exposure of national ID numbers, medical results, and payroll data.

This report was produced solely for the authorised educational engagement. All testing was performed within the defined scope and with explicit written permission. The techniques demonstrated must never be applied to any system without prior written authorisation from the system owner.

— End of Report —